TLP:CLEAR Unrestricted public release.

CYBER THREAT INTELLIGENCE REPORT

Binance details fake-recruiter intrusion behind roughly $6.3 billion crypto theft

From **Cybersecurity Briefing** · Covering 2026-10-30 to 2026-11-04 (US, Global, Industry and patches: last 24 hours, with the hard cutoff at 2026-10-30; Indianapolis and Indiana: five days) · Briefing generated 2026-11-04

REPORT ID	VERSION	HANDLING
CTI-20261104-05	1.0 · 2026-11-04 13:03 EST	TLP:CLEAR
BRIEFING SECTION	**ORIGINAL PUBLISHED**	**LAST UPDATE**
Global	2026-11-03	No update
CVES	**ANALYST**	
None	Nick Sturgeon	

NATION-STATE | CRITICAL | N/A | OVERALL CONFIDENCE: MODERATE

BOTTOM LINE UP FRONT

Binance published an initial incident report on 3 November 2026 explaining how attackers took about USD 6.34 billion in digital assets on 29 October [S1]. The intrusion was staged over months. In June, a Wallet DevOps engineer (Engineer A) installed a tampered Homebrew package while looking for an AI coding tool; Binance detected this, replaced the device and rotated credentials, but the engineer's role and wallet-team colleagues had already been exposed [S1]. In September, a second engineer (Engineer B) was approached on a job-hunting platform by a fake Project Director, sat through fake HR and CEO interviews, and ran a malicious 'assignment' repository on a work computer [S1] [S2]. By 20 October, the attacker had used that machine and an internal AI tool to gain control of Engineer A and Software Engineer C, and found a container deployment token on Engineer A's computer [S1]. On 29 October the attacker logged in to Engineer C's computer with Engineer A's stolen credentials, deployed a container, ran an attack script and reached the internal wallet signing service [S1].

No private key was reported stolen; Binance's own signing systems were made to approve the transfers [S5] [S17]. Roughly 20:05 to 23:56 UTC, funds left hot wallets on about 11 blockchains [S1] [S5]. On Ethereum, one transaction carried 50 pre-signed EIP-7702 authorizations that delegated a hot wallet to an attacker sweeper contract; that delegation kept draining the wallet after withdrawals were suspended, and because the wallet used multi-party computation, Binance had to write a special procedure to revoke it at 00:10 UTC on 30 October [S1] [S4] [S8]. Totals differ by source: Binance USD 6.34B, TRM USD 6.36B, Elliptic USD 6.43B, FBI 'more than' USD 6B [S1] [S4] [S5] [S20]. About USD 2.85B is frozen or intercepted,

while Binance separately says 98% of impacted token assets were replenished as of 31 October; these figures use different bases and should not be netted [S1] [S5].

The FBI, with the Secret Service and IRS Criminal Investigation, attributes the theft to North Korea's TraderTraitor activity [S10] [S11]. TRM and Chainalysis reached the same view from on-chain evidence, and Elliptic also assessed TraderTraitor as the likely culprit [S4] [S5] [S6]. Binance's report repeats the FBI's North Korea finding but does not make its own attribution or name a group [S1] [S2]. North Korea rejects the claim [S12]. The tradecraft closely resembles the Contagious Interview (WaterPlum) activity described in a September 2026 joint advisory, though Binance has not tied the incident to that campaign, and no source we reviewed equates WaterPlum with TraderTraitor [S2] [S16].

Binance's '0-day' label refers to custom malware that its endpoint tools did not detect, not to a disclosed software flaw; no CVE exists, and nothing suggests pyenv or Homebrew has a vulnerability [S1] [S2]. Binance published file paths but no hashes, command-and-control details, repository name or AI tool name, and says some details will stay confidential [S1]. The FBI address list could not be opened for this report. For most organizations the theft mechanics matter less than the path to them: block unvetted take-home code on corporate devices, inventory and shorten the life of deployment tokens, treat internal AI tools as privileged systems, and audit developer tool files on macOS for the reported tampering pattern.

Key judgments

VERY LIKELY · HIGH CONFIDENCE

North Korean state-linked operators, specifically the activity the FBI calls TraderTraitor, carried out the theft. Government attribution and three blockchain analytics firms agree, although the underlying government evidence is not public, Binance has not made its own finding, and Pyongyang denies involvement. [S1] [S4] [S5] [S6] [S10] [S12]

ALMOST CERTAIN · HIGH CONFIDENCE

North Korean operators will keep using recruiting lures and coding assignments against developers and DevOps staff over the next 12 months, given the scale reported for WaterPlum, the dozens of earlier interview compromises Chainalysis describes, and the payoff in this case. [S2] [S7] [S16] [S18]

LIKELY · MODERATE CONFIDENCE

Attackers will increasingly target internal AI tools and developer tooling on workstations as paths to lateral movement during the next year, because this case shows a large return from both. The exact way the Binance AI tool was abused is undisclosed, which limits confidence. [S1] [S18]

LIKELY · MODERATE CONFIDENCE

Most of the stolen value not already frozen will not be recovered. Elliptic reports about USD 3.25B in addresses that issuers cannot freeze, and laundering appears largely automated, though large holdings had not yet moved at the time of reporting. [S5] [S6] [S10]

ROUGHLY EVEN CHANCE · LOW CONFIDENCE

Binance or a partner will publish hashes or network indicators for the pyenv implant within 30 days. Binance promises an independent review but also says some details will remain confidential. [S1]

INDICATORS OF COMPROMISE

Host indicators for this intrusion come only from Binance's 3 November report, which gives file paths and sizes but no hashes or network indicators; on-chain indicators come from ThreatMon's 30 October analysis and CoinDesk and date to 29 October. Entries marked RELATED come from reporting on other campaigns and have no reported link to the Binance intrusion: use them for hunting context and do not treat a hit as evidence of this actor. The FBI's address list was not retrieved.

Type	Indicator (defanged)	Context	Provenance	First seen	Source
filepath	`/opt/homebrew/Cellar/pyenv/2.8.0/libexec/pyenv_`	Temporary malicious file created by the 'assignment' script, then modified to 3,414 bytes. Binance's report shows it with markdown escaping; the trailing underscore is confirmed by BleepingComputer's description.	REPORTED		[S1] [S2]
filepath	`/opt/homebrew/Cellar/pyenv/2.8.0/libexec/pyenv`	Legitimate 3,344-byte file was deleted and replaced by the renamed 3,414-byte malicious version. Treat the size as a clue only; legitimate sizes differ by pyenv version.	REPORTED		[S1]
filepath	`/opt/homebrew/bin/pyenv`	Existing link was deleted and recreated as a new symlink as part of the replacement.	REPORTED		[S1] [S2]
filename	`pyenv_`	Name of the temporary malicious file before it was renamed to pyenv.	REPORTED		[S1] [S2]
command	`ln (new pyenv symlink), then zsh spawned`	Final steps listed by Binance. Exact arguments were not published, so this is a behavior description and not a literal command line.	REPORTED		[S1] [S2]
filepath	`/opt/homebrew/Cellar/pyenv/*/libexec/pyenv_`	Wildcard of the reported path. The 2.8.0 segment is the installed version on the victim machine, and the script may adapt to other versions; a leftover file with this name would be abnormal.	DERIVED		[S1]
filepath	`/usr/local/Cellar/pyenv/*/libexec/pyenv_`	Equivalent location on Intel Macs, where Homebrew's default prefix is /usr/local. Binance reported only the /opt/homebrew path; whether the script handles this prefix is unknown.	DERIVED		[S1]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
wallet	`0x7C8601d4645b93cea45F71e118A729332e6B5CA0`	Ethereum attacker operator wallet funded through Tornado Cash; deployed the sweeper and sent the type-4 transaction and sweeps.	REPORTED	2026-10-29	[S8] [S9]
wallet	`0x63e842B054Bd624a465454D533C33F573e9c6fAe`	Attacker sweeper contract and EIP-7702 delegation target, deployed about 15:59 UTC.	REPORTED	2026-10-29	[S5] [S8] [S9]
wallet	`0x5227f603C1eE34CE3C06eFe6477003BDfCCB2f8c`	Attacker main collection address on Ethereum, Optimism, Arbitrum and Avalanche. Single-source (ThreatMon).	REPORTED	2026-10-29	[S9]
wallet	`0x8532FA14ACAf483729C449b8458aedDb900543D4`	Attacker Ethereum consolidation address holding about 195,460 ETH at time of report. Single-source (ThreatMon).	REPORTED	2026-10-29	[S9]
wallet	`TPBkSjkCMn2ckrMuAP8n2J1jdjbw76bKN4`	Tron address, listed by ThreatMon from Elliptic's blocklist.	REPORTED	2026-10-29	[S9]
wallet	`TG5iBMQPrDzJJAUM8GMVBf1hRaJ1wvzsGi`	Tron address, listed by ThreatMon from Elliptic's blocklist.	REPORTED	2026-10-29	[S9]
wallet	`rK21t6nGLy4MNDqhvy3pGwcLFy25qgfzMx`	XRP Ledger address, listed by ThreatMon from Elliptic's blocklist.	REPORTED	2026-10-29	[S9]
wallet	`AffzFDKZbyMiU11zmVBoAqD25ugpr7xoWWyRyGigBEaU`	Solana address marked 'likely' by ThreatMon; lower certainty.	REPORTED	2026-10-29	[S9]
wallet	`9SkjwUs5pRRQQo5a6g4m5cciy1xLdDeFnaov24htTjdQ`	Solana address marked 'likely' by ThreatMon; lower certainty.	REPORTED	2026-10-29	[S9]
other	`0x97408e7562eb2b28efcd24ba01609607b5749bc89448d007fa8b50ecf290329c`	Ethereum transaction: sweeper contract deployment, block 26299449.	REPORTED	2026-10-29	[S9]
other	`0xad99264d5532ae0dd04b2004eebda05f25657e70dacb764f7ac8d4ccd051298b`	Ethereum transaction at 20:20:59 UTC: type-4 transaction carrying 50 authorizations signed by Binance 14.	REPORTED	2026-10-29	[S8] [S9]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
other	`0x53bd38b816c23e74134786c29a8c18d792777998a3b9326047b583100e88e2f3`	Ethereum transaction at 20:24:23 UTC: first sweep, about 167,464 ETH and 63 tokens.	REPORTED	2026-10-29	[S8] [S9]
other	`0x51f263fa50966df6bbd7f8c6e6e99e3791c94444f7c4343b2fef1ee2d62fd39f`	Ethereum transaction at 20:24:47 UTC: Binance 16 sends 28,005.6 ETH to the collection address.	REPORTED	2026-10-29	[S9]
other	`0xdc102dd89dded5a83f1008906883ffb7c81ff3b7d7965d8c7277d170b5e17481`	Ethereum transaction at 20:41:23 UTC: callExecute pulling 780M USDC from Hot Wallet 34 per ThreatMon. TRM and CoinDesk give a total of 823M USDC from this route.	REPORTED	2026-10-29	[S4] [S8] [S9]
other	`0x55ba4dabc41b468e580751373ad31acdee6f5ba398682df2c93e5a8340870556`	Ethereum transaction at 21:44:11 UTC: second sweep.	REPORTED	2026-10-29	[S9]
other	`EIP-7702 authorizations for one account across nonces 18,914,775-18,914,824`	Behavioral signature of the signing-pipeline compromise on Binance 14. TRM independently advises treating many authorizations over consecutive nonces as a compromise indicator.	REPORTED	2026-10-29	[S4] [S9]
other	`0xef0100 code prefix returned by eth_getCode on a treasury or hot wallet`	Generic detection marker for an EIP-7702 delegation; not specific to this attacker. Relevant only to organizations holding EVM wallets.	REPORTED		[S9]
domain	`glowmedaesthetics[.]com`	RELATED: C2 for MacSync Stealer delivered through a fake Homebrew page. Binance links this SANS diary as a reference for the June event, but neither source confirms these indicators were on Engineer A's device.	REPORTED		[S1] [S13]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
url	`hxxp[://]glowmedaesthetics[.]com/curl/63810ee8b478575f3b2c6c46160c1fd338b213c6fc11bb0069dac9bbb7db237d`	RELATED: initial script download from the fake Homebrew campaign.	REPORTED		[S13]
url	`hxxps[://]sites[.]google[.]com/view/brewpage`	RELATED: fake Homebrew page reached through a malicious search ad; tracking parameters omitted.	REPORTED		[S13]
sha256	`a4fcfecc5ac8fa57614b23928a0e9b7aa4f4a3b2b3a8c1772487b46277125571`	RELATED: copy/paste script from the fake Homebrew page (225 bytes).	REPORTED		[S13]
sha256	`0d58616c750fc8530a7e90eee18398ddedd08cc0f4908c863ab650673b9819dd`	RELATED: initial zsh download (1,448 bytes).	REPORTED		[S13]
sha256	`86d0c50cab4f394c58976c44d6d7b67a7dfbbb813fbcf622236e183d94fd944f`	RELATED: zsh script decoded from base64 (2,647 bytes).	REPORTED		[S13]
filepath	`/tmp/osalogging.zip`	RELATED: archive of collected host data before exfiltration in the fake Homebrew campaign.	REPORTED		[S13]
md5	`9d78ece09457907b730d139e4e0c64dd`	RELATED: terraform-provider-awsbeta_v1.0.0, trojanized Terraform provider. Zscaler assesses suspected TraderTraitor overlap at low to moderate confidence; the post predates the theft and does not mention Binance.	REPORTED		[S14]
md5	`73adaea97f003735335505858c1c6def`	RELATED: safari_updater Bash loader.	REPORTED		[S14]
md5	`116f7189ed7b41f1b339a749d56e63be`	RELATED: HiraginoSans-Bold.woff, encrypted Mach-O x86_64 FLATROOF.	REPORTED		[S14]
md5	`be60c52ca8a01fef7dc15c2f0ebb77d8`	RELATED: HiraginoSans-Regular.woff, encrypted Mach-O arm64 FLATROOF.	REPORTED		[S14]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
md5	`58fa0d651898446d5f5d2ed8a27a3330`	RELATED: MalgunGothic-Bold.woff, encrypted PE32+ FLATROOF.	REPORTED		[S14]
md5	`2621753691be9521288664bb551dfba6`	RELATED: MalgunGothic-Italic.woff, encrypted PE32 FLATROOF.	REPORTED		[S14]
md5	`ad0b1b6d2c8b9d09d6473a4a299470ab`	RELATED: NotoSansCJK-Bold.woff, encrypted ELF x86-64 FLATROOF.	REPORTED		[S14]
md5	`4b8509cde757b5428e5f99c8dffe73ca`	RELATED: NotoSansCJK-ExtraBold.woff, encrypted ELF 32-bit ARM FLATROOF.	REPORTED		[S14]
md5	`3826dc7a9ba8bd5b1c143560c1530d89`	RELATED: NotoSansCJK-Italic.woff, encrypted ELF 32-bit Intel 80386 FLATROOF.	REPORTED		[S14]
md5	`34a52e6a4d803e94fe497bab682abfd3`	RELATED: NotoSansCJK-Regular.woff, encrypted ELF aarch64 FLATROOF.	REPORTED		[S14]
md5	`2b81aceab0142472d94eb42e500b27b1`	RELATED: imagent, macOS ROOFDECK backdoor.	REPORTED		[S14]
md5	`9d88b4494c7bc27b10358b68a899ad54`	RELATED: update.exe, Windows ROOFDECK backdoor.	REPORTED		[S14]
url	`hxxps[://]diagnose[.]hashicorp-terraform[.]io/plugins/grpc/v6/schema/metrics/333afe63-c5a2-43f0-b046-7cbaa7797e8a`	RELATED: Bash script download URL in the Terraform provider campaign.	REPORTED		[S14]
url	`hxxps[://]supportaru[.]serveftp[.]com/statics/cache/v11/`	RELATED: FLATROOF download URL.	REPORTED		[S14]
url	`hxxps[://]raw[.]githubusercontent[.]com/bluearuhost/hospitalrun-frontend/refs/heads/main/public/fonts/version1/`	RELATED: FLATROOF download location on GitHub.	REPORTED		[S14]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
url	`hxxps[://]stage-fashion365[.]vercel[.]app/static/tinymce4[.]7[.]5/plugins/fonts/v1104/`	RELATED: FLATROOF download URL.	REPORTED		[S14]
url	`hxxps[://]arusupport-region1-webhook[.]online/statics/cache/v11/abicfjej`	RELATED: FLATROOF C2 server.	REPORTED		[S14]
url	`hxxps[://]pastebin[.]com/raw/3yptBDhL`	RELATED: ROOFDECK C2 resolver on Pastebin.	REPORTED		[S14]
domain	`delay[.]servehttp[.]com`	RELATED: ROOFDECK C2 server.	REPORTED		[S14]
filename	`session.lock`	RELATED: file in the temp directory that prevents repeat execution of the Terraform provider stage. The name is common, so use only with other evidence.	REPORTED		[S14]
other	`awsbeta`	RELATED: malicious sibling package named in the Terraform provider campaign.	REPORTED		[S14]
wallet	`0xa322e5f3d311d3080e6f0121063e9adc2490ef1a`	RELATED: attacker wallet in the NullReceiver npm campaign; 68 transactions reported since 27 July. Chainalysis ties the technique generally to North Korea, but no source links this wallet to Binance.	REPORTED	2026-07-27	[S7] [S15]
wallet	`0xa658863ea658863e68656c6c6f6970626f742121`	RELATED: recurring NullReceiver destination address that encodes C2 data and is not meant to hold funds.	REPORTED	2026-07-27	[S15]
ipv4	`166[.]88[.]134[.]62`	RELATED: C2 IP in the NullReceiver npm campaign.	REPORTED		[S15]
other	`npm: bianira-ui`	RELATED: NullReceiver package, first published 28 July 2026, uploader npmuser1101.	REPORTED	2026-07-28	[S15]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
other	`npm: fluid-type-ui`	RELATED: NullReceiver package, first published 28 July 2026, uploader npmuser3002.	REPORTED	2026-07-28	[S15]
other	`npm: post-css-transfer`	RELATED: NullReceiver package added in the article's update.	REPORTED		[S15]
other	`npm: scrollbar-hide-plugin`	RELATED: NullReceiver package added in the article's update.	REPORTED		[S15]
other	`npm: tailwind-anim`	RELATED: NullReceiver package added in the article's update.	REPORTED		[S15]
other	`npm: tailwind-animation-founder`	RELATED: NullReceiver package added in the article's update.	REPORTED		[S15]
other	`npm: tailwindcss-anim`	RELATED: NullReceiver package added in the article's update.	REPORTED		[S15]

Indicators are defanged (hxxp, [.], [@]) so they cannot be clicked. "Reported" means stated in a source; "Derived" means inferred by the analyst from the source material and should be validated before blocking.

TACTICS, TECHNIQUES & PROCEDURES (TTPS)

The attacker combined patient social engineering with ordinary developer tooling. A June compromise of one wallet engineer, though detected and cleaned up, exposed the team map. In September a second engineer received a fake job process that built trust through video and chat interviews and ended in a malicious coding assignment. Its setup code replaced the Homebrew pyenv component on macOS with a malicious version that ran commands from an attacker server, spawned zsh, and tried to cover its tracks. From there the attacker abused an internal AI tool to control two wallet engineers, found a container deployment token, and on 29 October deployed a container and script that reached the wallet signing service. The signing service then approved ordinary transfers across several chains, plus EIP-7702 delegations on Ethereum that continued draining a hot wallet after withdrawals were suspended. Analyst note: pyenv is a good place to hide because developers invoke it routinely, so a replaced file may run repeatedly under the user's own context; this persistence reasoning is our inference, not a Binance statement. The 3,414-byte size is also small for a full custom implant, which suggests the replaced file may be a thin script or stager rather than the whole backdoor, although BleepingComputer describes a malicious binary; Binance has not resolved this [S1] [S2].

Threat actor

TraderTraitor · also tracked as Jade Sleet, Pressure Chollima, PUKCHONG, Slow Pisces, UNC4899, Lazarus Group (umbrella, per press), APT38 (per press)

Attribution confidence: High · **Motivation:** Financial theft for the North Korean state · **Suspected origin:** Democratic People's Republic of Korea

Attribution rests on the FBI, Secret Service and IRS-CI [S10] [S11], and on TRM (stated high confidence), Chainalysis and Elliptic, whose evidence includes commingling with Bitget exploit proceeds [S4] [S5] [S6]. Binance relays the FBI finding without naming a group or making its own attribution [S1] [S2]. North Korea rejects the claim [S12], and the Korea Times reports President Trump saying the US did not yet know whether North Korea was responsible [S11]. Alias lists vary by outlet; press equation of TraderTraitor with Lazarus and APT38 is looser than the vendor cluster names [S2] [S10] [S20]. Contagious Interview/WaterPlum uses similar lures, but no source we reviewed equates it with TraderTraitor or confirms a tie to this incident [S2] [S16].

MITRE ATT&CK mapping

Tactic	Technique	Procedure observed	Detection opportunity
Reconnaissance	T1591.004 Gather Victim Org Information: Identify Roles	The June compromise exposed Engineer A's role and wallet infrastructure colleagues. [S1]	After any developer endpoint incident, assume team data and repository knowledge are exposed, and review access for adjacent staff.
Reconnaissance	T1593.001 Search Open Websites/Domains: Social Media	Engineer B's job platform profile mentioned Binance experience. That this drove target selection is our inference. [S2]	Limited technical visibility; advise staff in sensitive roles about what they publish and to report recruiter approaches.
Resource Development	T1585.001 Establish Accounts: Social Media Accounts	Fake Project Director, HR and CEO personas for a nonexistent company; the HR persona shared a social account with personal photos and video to build trust. [S1] [S2]	Verify the hiring company independently; report interview requests that move to chat apps.

Tactic	Technique	Procedure observed	Detection opportunity
Resource Development	T1583.008 Acquire Infrastructure: Malvertising	June event: an engineer searching for an AI coding tool obtained a tampered Homebrew installation. NBC/Reuters mention an advertisement, and Binance links a SANS diary on Homebrew malvertising; the exact chain on Engineer A's machine is not confirmed. [S1] [S12] [S13]	DNS and proxy monitoring for lookalike package-manager sites; prefer managed software catalogs.
Initial Access	T1566.003 Phishing: Spearphishing via Service	Approach on a legitimate job-hunting platform, then a chat app, ending with a request to download an assignment from a code repository. [S1] [S2] [S3]	Hunt for repositories cloned to corporate endpoints soon after chat-app or recruiter activity; platform names are undisclosed.
Execution	T1204.002 User Execution: Malicious File	Engineer B ran malicious setup code from the assignment repository on a work computer. [S1] [S3]	Alert on package managers or setup scripts in newly cloned repositories that spawn curl, wget or base64 decoding.
Execution	T1059.004 Command and Scripting Interpreter: Unix Shell	The script spawned zsh after replacing pyenv; the malicious component ran commands from an attacker server. [S1] [S2]	Parent-child telemetry for pyenv launching zsh with network activity nearby.
Persistence	T1554 Compromise Host Software Binary	Replaced the Homebrew pyenv component in Cellar and recreated its bin symlink. [S1] [S2]	File integrity monitoring on Homebrew Cellar and bin directories; compare against a clean reinstall of the same version.
Defense Evasion	T1027 Obfuscated Files or Information	Binance describes obfuscation and evasion used to avoid detection by endpoint protection. [S1] [S2]	Behavioral rules, since static signatures missed the sample.
Defense Evasion	T1070.004 Indicator Removal: File Deletion	Deleted the legitimate pyenv and link, and removed forensic artifacts. [S1] [S3]	Delete-then-rename sequences in Homebrew directories by a process other than brew.
Defense Evasion	T1036.005 Masquerading: Match Legitimate Resource Name or Location	The malicious file took the name and location of the legitimate pyenv file. [S1]	Hash and size comparison with a known-good install.

Tactic	Technique	Procedure observed	Detection opportunity
Command and Control	T1071 Application Layer Protocol	The implant reached an attacker-controlled server for commands. The protocol is not stated; this mapping is a best fit. [S1] [S2]	Outbound connections from pyenv or its child shells to new destinations.
Credential Access	T1528 Steal Application Access Token	The attacker found and took a container deployment permission token on Engineer A's computer, along with credentials. [S1] [S2]	Token use from unexpected hosts or times; secret scanning on endpoints and developer home directories.
Lateral Movement	T1072 Software Deployment Tools	Abuse of an internal AI tool gave control over Engineers A and C. The mechanism is undisclosed, so this is the closest fit and not a confirmed mapping. [S1] [S3]	Audit logs from internal AI tools: unusual users, tool invocations, connector use, and actions touching other users' endpoints.
Lateral Movement	T1021 Remote Services	Attacker logged in to Engineer C's computer using credentials stolen from Engineer A on 29 October. [S1] [S3]	Logins between developer workstations and logins with one person's credentials on another person's device.
Execution	T1610 Deploy Container	Deployed a container and triggered the attack script that reached the wallet signing service. [S1] [S3] [S17]	Workload creation by human identities or outside the CI/CD path, especially in signing namespaces.
Impact	T1657 Financial Theft	Malicious signing requests moved funds on about 11 chains. EIP-7702 delegations let a sweeper contract drain Binance 14 repeatedly after withdrawals stopped. [S1] [S4] [S5] [S8] [S9]	Signing-policy alerts on unexpected destinations, velocity, type-4 transactions and consecutive-nonce authorizations; poll wallets for delegation code.

Detection & hunting

Queries are built from the reported behavior and indicators. They are untested; tune field names for your environment.

Tampering with Homebrew pyenv on macOS SIGMA

```
title: Homebrew pyenv Component Replaced By Non-Brew Process
status: experimental
logsource:
  product: macos
  category: file_event
detection:
  selection_temp:
    TargetFilename|contains: '/Cellar/pyenv/'
    TargetFilename|endswith: '/libexec/pyenv_'
  selection_target:
    TargetFilename|contains: '/Cellar/pyenv/'
    TargetFilename|endswith: '/libexec/pyenv'
  filter_brew:
    Image|contains:
      - '/Homebrew/'
      - '/brew'
  condition: selection_temp or (selection_target and not filter_brew)
level: high
```

Built from Binance's file list. Expect some noise during pyenv upgrades; extend the filter for your deployment tool. Requires macOS EDR file telemetry, and field names vary.

pyenv spawning a shell with outbound connections nearby `KQL`

```
let suspects = DeviceProcessEvents
| where Timestamp > ago(30d)
| where InitiatingProcessFileName =~ "pyenv" or InitiatingProcessFolderPath has "/Cellar/pyenv/"
| where FileName in~ ("zsh", "sh", "bash")
| project DeviceId, ShellTime = Timestamp, ShellCommand = ProcessCommandLine, ShellPid = ProcessId;
suspects
| join kind=inner (
    DeviceNetworkEvents
    | where Timestamp > ago(30d)
    | where RemoteIPType == "Public"
    | project DeviceId, NetTime = Timestamp, RemoteUrl, RemoteIP, InitiatingProcessFileName,
InitiatingProcessId
) on DeviceId
| where NetTime between (ShellTime .. (ShellTime + 5m))
| where InitiatingProcessId == ShellPid or InitiatingProcessFileName =~ "pyenv"
| project DeviceId, ShellTime, ShellCommand, NetTime, RemoteUrl, RemoteIP
```

Legitimate pyenv spawns shells often, so the network correlation is what narrows the results. For Microsoft Defender for Endpoint on macOS. Baseline first and review developer endpoints.

Container deployment by a human identity or from outside CI/CD `SPLUNK SPL`

```
index=kubernetes sourcetype=kube:apiserver:audit verb=create (objectRef.resource=pods OR
objectRef.resource=deployments OR objectRef.resource=jobs) responseStatus.code<300
| search NOT user.username="system:serviceaccount:*"
| stats count min(_time) AS first max(_time) AS last values(sourceIPs{}) AS src_ip
values(objectRef.namespace) AS namespace values(userAgent) AS agent BY user.username
| convert ctime(first) ctime(last)
```

Generic form of the 29 October step. Adjust index and sourcetype to your platform, and add stolen-token coverage by also reviewing service account use from source IPs outside CI runners. Prioritize namespaces that handle signing, secrets or production deployment.

REMEDIATION ACTIONS

Exposure

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
Homebrew pyenv on macOS developer workstations (abused component, not a product flaw)	Reported path shows pyenv 2.8.0; no vulnerable version range applies	N/A: no patch. Reinstall from a trusted source and rebuild if tampering is found	None	N/A	N/A (no CVE)	No	N/A
EVM hot wallets and signing services (for organizations that hold crypto)	Key-controlled wallets able to sign EIP-7702 authorizations, available since Ethereum's Pectra upgrade in May 2025	N/A: signing-policy and monitoring controls	None	N/A	N/A (no CVE)	No	N/A

Immediate (0–24 hours)

- Search macOS endpoints for a pyenv_ file under Homebrew Cellar paths and for recent changes to the pyenv libexec file and bin link not tied to a brew upgrade. Isolate any confirmed host and treat its credentials as stolen. `SOC` [S1] [S2]
- Tell developer, DevOps and IT staff not to run interview tests or recruiter-supplied code on corporate devices, and to report any such activity since June without penalty. `LEADERSHIP` [S2] [S9] [S16]
- If your organization holds or processes crypto, screen against the FBI address list and vendor blocklists, and alert on any delegation code on wallets you control. `SOC` [S4] [S9] [S10] [S20]
- List deployment, container registry and cloud tokens stored on developer laptops; revoke those that are unused or long-lived. `IT OPS` [S1] [S9]

Short term (1–7 days)

- Provide an isolated VM or non-corporate machine for evaluating outside code, and instruct staff to inspect projects for commands that fetch payloads. `IT OPS` [S9] [S16]
- Add file integrity monitoring and EDR rules for Homebrew directories and other developer tool paths; test against the reported delete, rename and symlink sequence. `SOC` [S1]
- Review internal AI tool permissions and logs: who can use them, what connectors they hold, whether they can act on other users' systems, and whether use is logged to the SIEM. `IT OPS` [S1] [S3]
- Route software installs through managed catalogs and block sponsored-result installs for developer tools through policy and DNS filtering where possible. `IT OPS` [S1] [S13]
- After any developer compromise, widen scoping to teammates and shared access, since the June cleanup at Binance did not remove what the attacker had already learned. `SOC` [S1]

Long term

- Move to short-lived, device-bound production tokens, and restrict deployment to CI/CD identities with human approval for sensitive workloads. `IT OPS` [S9]
- For signing systems: put a policy engine in a separate trust domain, enforce destination allow-lists and value limits, reject unexpected EIP-7702 requests, and separate paths by chain and wallet tier. `IT OPS` [S4] [S9]
- Run tabletop exercises for fast revocation and for contact with stablecoin issuers and law enforcement; quick freezes were among the most effective responses here. `LEADERSHIP` [S1] [S4] [S9]
- Add identity and location checks to hiring, and least-privilege starting access, because the same North Korean ecosystem also places IT workers inside companies. `LEADERSHIP` [S7] [S16] [S18]
- Treat staff in deployment and privileged roles as high-risk users, with stronger device controls and targeted awareness on recruiter lures. `LEADERSHIP` [S7] [S18]

Workarounds & compensating controls

- Where take-home code cannot be blocked outright, restrict it with application control and network egress limits on developer machines, and keep secrets out of the home directory and environment variables. `IT OPS` [S9] [S16]
- Block personal-to-corporate peer-to-peer transfers such as AirDrop, and detect session cookie reuse from new IP addresses or VPNs. `IT OPS` [S9]
- Set kill-switch triggers for large simultaneous outflows across multiple chains, for organizations operating wallets. `SOC` [S9]

Actions marked with an owner: SOC = security operations, IT Ops = system and network administration, Leadership = risk and communications decisions.

SOURCES

[S1] Binance: Security incident report on the 29 October 2026 incident (initial report)
Published 2026-11-03 · **A2** Completely reliable, probably true
Primary source from the victim. Preliminary, partly withheld, and subject to independent review. Title is descriptive.

[S2] BleepingComputer: Binance says fake job interview led to $6.3 billion crypto heist
Published 2026-11-03 · **B2** Usually reliable, probably true
Briefing source. Clear on the macOS file sequence and on the lack of a campaign link.

[S3] The Hacker News: Binance reveals how fake job interviews led to the theft
Published 2026-11-03 · **B2** Usually reliable, probably true
Briefing source. Uses USD 6.43B, which matches Elliptic and not Binance's USD 6.34B. Title is descriptive, taken from the URL.

[S4] TRM Labs: North Korea Steals USD 6.36 Billion From Binance in the Largest Hack in History
Published · **B2** Usually reliable, probably true
On-chain timeline to a 30 October 00:30 UTC snapshot. Publication date not confirmed. Predates Binance's root cause, and its ETH figures do not fully reconcile.

[S5] Elliptic: The largest theft in history: North Korea likely behind the $6.4 billion Binance hack
Published · **B2** Usually reliable, probably true
On-chain and laundering analysis, updated after the FBI attribution. Publication date not confirmed.

[S6] Chainalysis: Binance Hack: Tracing the $6.4 Billion Theft to North Korea
Published 2026-10-30 · **B2** Usually reliable, probably true
Attribution evidence and freezes, with a figure as of 3 November.

[S7] Chainalysis: DPRK fake interview playbook and the Binance hack
Published · **B2** Usually reliable, probably true
Context on earlier interview compromises and blockchain-based C2. Publication date not confirmed; cited by S3 on 3 November. Title is descriptive.

[S8] CoinDesk: Here's how an Ethereum upgrade helped drain part of Binance's $6 billion loss
Published 2026-10-30 · **B1** Usually reliable, confirmed by other sources
EIP-7702 mechanics and linked on-chain identifiers, which match S9.

[S9] ThreatMon: Binance Lost $6.3 Billion Without Losing a Key
Published 2026-10-30 · **C2** Fairly reliable, probably true
Main source for addresses and transaction IDs. Written before Binance's report and before government attribution. Some entries single-source.

[S10] The Hacker News: FBI links North Korea's TraderTraitor to the Binance theft
Published 2026-11-01 · **B2** Usually reliable, probably true
Relays the FBI alert, co-issuing agencies, aliases and laundering pattern; also covers related malware. Title is descriptive, taken from the URL.

[S11] The Korea Times: FBI says N. Korea responsible for over $6 bil. crypto theft from Binance
Published 2026-11-01 · **B2** Usually reliable, probably true
Relays the alert and US political statements.

[S12] NBC News (Reuters): Binance says hackers used fake job interview to breach computer before $6.3 billion attack
Published · **B2** Usually reliable, probably true
Mentions the June advertisement and North Korea's rejection. Publication date not confirmed.

[S13] SANS Internet Storm Center: Malvertising campaign delivering MacSync Stealer via fake Homebrew page (diary 32942)
Published 2026-05-01 · **A3** Completely reliable, possibly true
Solid technical source, and linked by Binance. It predates and does not mention the incident, so the tie to Engineer A is unconfirmed. Title is descriptive.

[S14] Zscaler ThreatLabz: Suspected TraderTraitor group uses trojanized Terraform provider
Published 2026-10-08 · **B3** Usually reliable, possibly true
Related campaign only. Author's attribution is low to moderate confidence; no Binance link. Title is descriptive, taken from the URL.

[S15] The Hacker News: Trojanized npm packages decode C2 IP (NullReceiver)
Published 2026-08-05 · **B3** Usually reliable, possibly true
Related technique only; updated 6 August. No Binance link. Title is descriptive, taken from the URL.

[S16] BleepingComputer: North Korean WaterPlum hackers infected 30,000 devices worldwide
Published 2026-09-19 · **B2** Usually reliable, probably true
Summarizes the 18 September joint advisory. The advisory PDF could not be read by our tools.

[S17] BleepingComputer: Binance links $6.3 billion crypto theft to compromised DevOps laptop
Published 2026-10-30 · **B2** Usually reliable, probably true
Binance's early position, later expanded by S1.

[S18] Microsoft Threat Intelligence: Tracking AI adoption in North Korean threat actor tradecraft
Published 2026-10-29 · `A2` Completely reliable, probably true
Context on interview lures and AI use. Does not mention Binance.

[S19] CryptoImpactHub: FBI Attributes $6B+ Binance Theft to North Korea's TraderTraitor, Publishes Addresses
Published · `C3` Fairly reliable, possibly true
Only source opened for the 628-address breakdown; the 31 October alert date also appears in S5. Publication date not confirmed.

[S20] Security Affairs: FBI Blames North Korea for $6 Billion Binance Crypto Theft
Published · `C2` Fairly reliable, probably true
Relays the alert's request to block transactions, including derived funds. Publication date not confirmed.

Grades use the Admiralty scale: letter = source reliability (A completely reliable to F cannot be judged), number = information credibility (1 confirmed to 6 cannot be judged).

MISCELLANEOUS

Timeline

Date	Event	Source
2026-05-01	SANS ISC documents a fake Homebrew page delivered through search ads; Binance later links this diary when describing its June event.	[S1] [S13]
2026-06	Engineer A installs a tampered Homebrew package while seeking an AI coding tool. Binance detects it, replaces the device and rotates credentials, but the team map is exposed.	[S1]
2026-09	Engineer B is approached on a job platform, completes two fake interviews, and runs a malicious assignment repository on a work computer.	[S1] [S2]
2026-09-18	Joint advisory on WaterPlum (Contagious Interview) is published by Japanese, US, Australian and German agencies.	[S16]
2026-10-20	Attacker uses Engineer B's machine and an internal AI tool to gain control of Engineers A and C, and finds a container deployment token.	[S1]
2026-10-28	Attacker operator wallet receives small Tornado Cash withdrawals; Elliptic reports three of 0.1 ETH between 28 and 29 October.	[S4] [S5]
2026-10-29	15:59 UTC: sweeper contract deployed. 17:15 to 19:56 (time zone not stated): login to Engineer C's computer, container deployed, attack script triggered.	[S1] [S5]

Date	Event	Source
2026-10-29	20:05 to 20:09 UTC: 233.46M XRP moved, followed by Solana, Optimism, BTC and others. 20:20:59 UTC: 50-authorization transaction. 20:24:23 UTC: first Ethereum sweep.	[S1] [S4] [S8] [S9]
2026-10-29	From about 21:01 UTC: issuers begin freezing funds. 23:56 UTC: final unauthorized transfer of 2,961.9 ETH finalizes.	[S1] [S4]
2026-10-30	00:10 UTC: Binance revokes the EIP-7702 delegation from Binance 14. Binance links the theft to a DevOps laptop and notes more breach points.	[S1] [S8] [S17]
2026-10-31	FBI attributes the theft to TraderTraitor (date per Elliptic and CryptoImpactHub). Binance says about 98% of impacted token assets are replenished.	[S1] [S5] [S19]
2026-11-03	Binance publishes its initial incident report; about USD 2.85B is reported frozen or intercepted.	[S1] [S2]

Relevance to Indianapolis, Indiana & managed clients

No source reports an Indianapolis or Indiana victim, and most organizations here do not run crypto wallet infrastructure, so the on-chain indicators matter mainly to any firm that holds or handles digital assets. The entry path applies far more broadly. Software teams at Indiana manufacturers, healthcare organizations, insurers, universities and government agencies have staff who hold deployment tokens, install tools with Homebrew and may be looking for jobs. North Korean recruiting lures have reached at least 30,000 devices in more than 100 countries, and compromised machines can be used to pivot into employer or client networks [S16], so a smaller employer is not out of scope. Students and recent graduates in Indiana's computing programs fit the job-seeker profile, and an infected machine used on a campus or employer network could put both at risk. For managed IT service clients the closest parallel is the technician or administrator laptop: stored RMM, cloud and deployment tokens could give one compromised person broad reach across several customers. Small and mid-size businesses should prioritize a written rule against running recruiter-supplied code on company devices, token inventory, macOS EDR coverage if developers use Macs, identity checks for remote hires, and a clear limit on what internal AI assistants can reach. Recovery here relied on rapid freezes and very large reserves that a smaller organization will not have, so prevention and early detection carry more weight [S1] [S4].

Intelligence gaps

- The FBI alert returned HTTP 403 to our tools, so the full address list and the exact alert text were not reviewed: https://www.fbi.gov/investigate/cyber/alerts/2026/north-korea-responsible-for-6-billion-binance-attack. Retrieve it manually in a browser. A secondary source reports 628 addresses (608 Ethereum, 19 Bitcoin, 1 Solana) [S19], which is unverified.
- Hashes, C2 infrastructure, repository name, job platform, chat app and internal AI tool name are unpublished [S1] [S2].
- How the internal AI tool was abused, and how that yielded control of two other engineers' machines, is unknown. This is the most useful missing detail for defenders.
- It is unclear how the assignment achieved execution, whether the pyenv file is itself the implant or a stager, and whether Windows or Linux variants exist. No analysis of the sample was found.

- The 17:15 to 19:56 window has no stated time zone. If it is UTC, on-chain preparation (15:59 UTC) began before the reported login, which would mean earlier undisclosed access or separate preparation [S1] [S5].
- Whether the June compromise contributed to the September access beyond exposing team information is undetermined, as is whether it was truly the same actor; Binance presents it as part of the same campaign [S1].
- Binance has not fully explained which controls failed at the signing service or how 50 authorizations were approved [S1] [S8]. Watch for the independent review, FBI address updates and any Treasury sanctions.
- The Hacken analysis, The Hill coverage and the joint advisory PDF could not be read and were not relied on.

Other notes

- Do not block or alert on these Binance-owned wallets as attacker addresses: Binance 14 0x28C6c06298d514Db089934071355E5743bf21d60, Binance 16 0xDFd5293D8e347dFe59E90eFd55b2956a1343963d, Hot Wallet 34 0xEe7aE85f2Fe2239E27D9c1E23fFFe168D63b4055 [S9]. Transaction 0xafbf94c92a8d749988411669fa14d4f8866d9b4420b4ebd299f28e958dac7209 is Binance's own revocation at 00:10:35 UTC on 30 October [S8] [S9].
- Correction to the briefing framing: the September recruiter contact was not the first stage. Binance describes a June compromise of Engineer A, so the campaign ran for at least about four months [S1]. Also, Binance does not name a group but its report does repeat the FBI's North Korea finding [S1].
- Figures vary. Theft totals: USD 6.34B (Binance), 6.36B at time of theft and 6.23B at later prices (TRM), 6.43B (Elliptic), about 6.4B (Chainalysis). Frozen: USD 2.85B (Binance, Elliptic), about 2.8B (Chainalysis at 3 November), about 2.7B (TRM at 30 October), about 3B (CoinDesk) [S1] [S4] [S5] [S6] [S8]. Chain counts: 11 (Elliptic, The Hacker News) versus 10 (ThreatMon, earlier) [S5] [S9] [S10].
- Sources describe the June event differently: a tampered Homebrew installation (Binance), a trojanized Homebrew installer (The Hacker News), and a tampered AI tool following an advertisement (NBC/Reuters). The SANS diary Binance links describes search-ad malvertising with a copy/paste Terminal command [S1] [S3] [S12] [S13].
- Elliptic says its free blocklist has more than 8,000 addresses, whereas ThreatMon on 30 October cited 45 entries at data-cdn.elliptic.co/blocklists/binance-hack-blocklist.csv. The difference probably reflects growth over time, though we did not download the file; ask Elliptic for the current list [S5] [S9].
- Elliptic and Chainalysis report commingling with proceeds of the September 2026 Bitget exploit, with Elliptic also citing shared services with earlier TraderTraitor thefts [S5] [S6]. Elliptic reports laundering patterns that suggest software automation, but says on-chain data cannot show whether AI agents were involved [S5].
- The FBI reportedly observes conversion mainly into ETH and expects more laundering through DeFi and instant swap services, and asks providers including THORNode and RPC operators to block these addresses and derived funds [S10] [S20].
- As of 30 October, Binance said user funds were safe and it would cover losses, and ThreatMon found no evidence of customer data exposure; neither statement is an independent audit [S9] [S17]. Binance also reports having stopped 57 suspected North Korea-linked cases in 2026, showing that this pressure on its staff was sustained [S1].

- Microsoft's October report says several North Korean groups use interview-themed lures and AI tools to support them, and Zscaler reported a suspected TraderTraitor campaign against cryptocurrency and Web3 developers through Terraform providers. Neither is linked to this theft, but both show targeting of developer tooling [S14] [S18].

CTI-20261104-05 v1.0 · Generated 2026-11-04 13:03 EST from public reporting. Drafted with AI assistance and reviewed by Nick Sturgeon. Verify indicators and actions before operational use. Summaries are in the analyst's own words.

Back to the daily briefing.

TLP:CLEAR Unrestricted public release.